

Power Platform Governance Cookbook

Scenario-Based Guidance for Enterprise-Scale Management and Security

Use this cookbook to ensure your Power Platform adoption is controlled, compliant, and secure — while empowering makers within safe guardrails.

July 2026

Table of Contents

Table of Contents..... 2

Overview..... 3

Governance Principles and Operating Model 3

Recipe Summary 4

Recipe 1: Enforce Data Policies / DLP Policies 5

 Connector Classifications 5

 Policy Scope & Tiering 5

Recipe 2: Establish Environment Strategy 6

 Environment Types..... 7

 Key Practices 7

Recipe 3: Manage the Default Environment 8

Recipe 4: Implement Managed Environments for Scale 9

 Key Managed Environment Features 9

Recipe 5: Require Security and Compliance 10

Recipe 6: Monitor Usage, Compliance, and Performance 11

Recipe 7: Enable ALM and Change Control..... 13

 ALM Practices Summary 13

Recipe 8: Govern Environment Creation and Lifecycle 14

Recipe 9: Govern Connectors, Custom Connectors, and HTTP Actions 15

Recipe 10: Govern Copilot Studio and AI Agents 16

Recipe 11: Manage Inventory, Ownership, and Criticality 17

Recipe 12: Govern Licensing, Capacity, and Cost 19

Recipe 13: Strengthen Tenant and Advanced Data Protection Controls 20

Naming Conventions..... 22

Exception Process 23

Governance Validation Checklist 24

Closing Principles 26

Overview

This Governance Cookbook provides scenario-based guidance for managing and securing the Power Platform at enterprise scale. Each "recipe" maps a typical requirement or policy goal to concrete Power Platform features and administrative actions that implement it. All guidance aligns with Microsoft's Power Platform governance best practices, including the Power Platform Admin documentation and the Well-Architected Framework.

Each recipe stands alone but cross-references others for comprehensive governance. Use this cookbook to:

- Control and secure Power Platform at enterprise scale
- Map policy goals to concrete product features and admin actions
- Empower makers within safe, well-defined guardrails
- Maintain compliance without stifling innovation and agility

Governance Principles and Operating Model

PPAC-first governance principle: Use the Power Platform Admin Center as the primary experience for governance, monitoring, inventory, security, and administrative actions. Prefer native capabilities such as Inventory, Usage, Monitor, Actions, Managed Environments, environment groups, rules, delegated admin, and environment routing. Use the CoE Starter Kit or custom governance solutions only when PPAC does not provide the required capability, and document the gap, owner, support model, and retirement criteria.

Governance Role	Primary Responsibilities
Platform team	Defines tenant-wide policies, manages PPAC settings, owns environment strategy, monitors risk, and maintains governance standards.
Environment admin	Manages assigned environments, security groups, makers, capacity, and operational controls within approved boundaries.
Maker	Builds solutions within guardrails, follows naming and ALM standards, documents ownership, and requests exceptions when needed.
Business owner	Owns business value, criticality, user adoption, compliance impact, and continuity of production solutions.
Security and compliance team	Reviews sensitive scenarios, validates data protection controls, and approves exceptions for regulated workloads.

Decision rule: use PPAC when a native capability exists; use Power Platform APIs, CLI, connectors, or automation when scale or integration requires it; use CoE Starter Kit or a custom solution only for documented gaps not yet covered by PPAC.

Recipe Summary

The table below provides a quick-reference index of all governance recipes covered in this cookbook.

Recipe	Scenario	Key Features
1. Enforce Data Policies / DLP	Prevent data leakage via connectors	Connector classification, Tenant & environment scope, Tiered policies
2. Environment Strategy	Structured Dev/Test/Prod separation	Dedicated environments, Security groups, Managed solutions
3. Manage Default Environment	Reduce clutter in the default environment	Data policies, PPAC Inventory/Usage/Monitor/Actions, Maker welcome message
4. Implement Managed Environments	Consistent governance at scale	Managed Environments, environment groups, rules, routing, sharing limits
5. Security & Compliance	Enforce strong security for makers/admins	MFA/Conditional Access, Role separation, Audit logging
6. Monitor Usage & Compliance	Continuous operational oversight	PPAC Inventory/Usage/Monitor/Actions, Azure Monitor, license and capacity review, compliance audits
7. Enable ALM & Change Control	Governed deployment to production	Pipelines, Stage gates, Managed solutions, Versioning
8. Govern Environment Creation & Lifecycle	Control who can create environments and prevent sprawl	PPAC creation controls, security groups, Managed Environments, environment groups, routing, lifecycle review
9. Govern Connectors & HTTP Actions	Control connector, custom connector, and HTTP usage	Data policies, advanced connector policies, endpoint filtering, exception review
10. Govern Copilot Studio & AI Agents	Enable agent innovation with security, ownership, and publishing controls	Data policies for agents, environment routing, knowledge source controls, publishing review, audit logs
11. Manage Inventory, Ownership & Criticality	Keep apps, flows, agents, and environments discoverable, owned, and risk-ranked	PPAC Inventory, ownership transfer, orphaned assets, criticality tiers, recertification
12. Govern Licensing, Capacity & Cost	Control premium usage, capacity growth, and financial exposure	License review, capacity add-ons, premium connectors, API limits, PAYG, chargeback/showback
13. Strengthen Tenant & Advanced Data Protection	Reduce cross-tenant, encryption, and privileged access risk	Tenant isolation, allow lists, guest governance, customer-managed keys, Customer Lockbox

Recipe 1: Enforce Data Policies / DLP Policies

Scenario: *"We need to prevent business data from accidentally leaving our organization via Power Platform connectors."*

Set up data policies, commonly known as DLP policies, to control connector usage across your Power Platform environments. Data policies are a primary defense against accidental data exfiltration via connectors.

Quick Reference

- Use PPAC data policies as the primary control for reducing connector-based data exfiltration risk.
- Classify connectors as Business, Non-Business, or Blocked based on trust, sensitivity, and data movement risk.
- Set a conservative default connector group for new connectors so newly released connectors do not become broadly usable before review.
- Apply baseline tenant-wide policies first, then add stricter environment-level or environment group policies for regulated workloads.
- Review design-time and runtime impact before policy changes because enforcement timing and latency can affect existing apps and flows.

Connector Classifications

In the Power Platform Admin Center, classify every connector into one of three groups:

Classification	Description	Examples
Business	Trusted, approved connectors carrying organizational data	SharePoint, Outlook, Teams, internal APIs
Non-Business	Unapproved or risky connectors — cannot mix with Business	Social media connectors, public SMS services
Blocked	Completely disallowed connectors; prevent all usage	High-risk third-party data services

Business and Non-Business connectors cannot be used together in the same app or flow. This boundary prevents data from crossing trust zones.

Policy Scope & Tiering

- Tenant-Wide Policies — apply global rules across all environments (e.g., no Business connector mixed with a Non-Business connector anywhere).
- Environment-Level Policies — add stricter rules for high-security or specialized environments without affecting others.
- Tiered Approach — layer multiple policies: a broad baseline policy plus focused policies for specific environments.

Maintenance

- Regularly review connector lists as Microsoft publishes new connectors.
- Use the Policy Summary view in the Admin Center to identify apps or flows blocked by DLP.
- Remediate violations by adjusting solution design or carefully updating policies.

Validation Signals

- All production and regulated environments have a data policy assigned.
- Connector exceptions are documented with owner, justification, scope, expiration date, and review cadence.
- New connectors are reviewed before being allowed in sensitive environments.
- Blocked apps or flows are reviewed and remediated through design changes or approved policy updates.

Common Risks

- Overly permissive connector classification can allow sensitive data to move into unapproved services.
- Overly restrictive policies can block legitimate business processes if exceptions and migration paths are not planned.
- Policy changes can affect existing apps and flows, so impact analysis and communication are required.
- Ignoring custom, virtual, and HTTP-related connectors leaves important integration paths unmanaged.

Recipe 2: Establish Environment Strategy

Scenario: *"We want a structured approach to environments — separating development, test, and production, and controlling who can create environments."*

Implement a formal environment lifecycle to provide structure, reduce risk, and enforce proper ALM (Application Lifecycle Management) practices.

Quick Reference

- Separate development, test, UAT, production, sandbox, and default environment purposes.
- Restrict non-default environments with security groups and clear maker/admin role assignments.
- Use dedicated environments for production-grade, sensitive, or broadly shared solutions.
- Plan region, data residency, capacity, and lifecycle before environment creation.
- Use managed solutions and pipelines to move changes across environments.

Environment Types

Environment Type	Purpose	Access Control
Development	Building and unit testing apps/flows	Dev team makers via security group
Test / UAT	User acceptance and integration testing	QA team + selected business users
Production	Live workloads for end users	Read-only for makers; admin-managed
Sandbox / Trial	Innovation, prototyping, experimentation	Open to exploratory makers with DLP guardrails
Default	Personal productivity only (not for critical apps)	All users (Maker by default); restrict via DLP

Key Practices

- Security Group Control — assign a Security Group to every non-default environment to restrict who can be a Maker or Consumer.
- Environment Roles — use built-in Environment Admin and Maker roles. Minimize admin role assignments; remove the "Everyone" maker permission where unnecessary.
- Deployment via Managed Solutions — mandate that all apps move between environments as managed solutions; developers build in Dev (unmanaged), then export/import to Test and Prod as managed.
- Environment Lifecycle — reset Dev/Test environments regularly (sanitized Prod data if needed) and retire unused environments to reduce sprawl.

Validation Signals

- Every non-default environment has documented purpose, owner, lifecycle stage, region, and security group.
- Production workloads are not running in personal, trial, or default environments.
- Environment creation follows an approved request path.
- Dev/Test/Prod environments use consistent naming and ALM flow.

Common Risks

- Environment sprawl increases operational complexity, cost, and security exposure.
- Poor separation between development and production increases the chance of untested changes affecting users.
- Incorrect region selection can create data residency or latency concerns.
- Missing security groups can make environment access harder to govern at scale.

Recipe 3: Manage the Default Environment

Scenario: *"Our default environment is getting cluttered with random apps. We need to control or reduce misuse of the Default environment."*

The default environment is intended for personal productivity, but it often fills up with production-grade apps. The following measures bring it under control:

Quick Reference

- Treat the default environment as personal productivity only, not as a production hosting location.
- Apply restrictive data policies to reduce risky connector combinations.
- Use PPAC Inventory, Usage, Monitor, and Actions to identify high-usage, broadly shared, ownerless, or risky assets.
- Promote production-grade assets to dedicated governed environments.
- Use maker welcome messages to explain environment guidance and escalation paths.
- Limit Purpose — communicate and enforce that the default environment is for personal or trial use only. Encourage teams to request a dedicated environment for official apps.
- Restrict Maker Access — apply strict DLP policies to the default environment (e.g., allow only very safe connectors, or mark all connectors as Business to block Non-Business mixing). This makes building risky apps in default infeasible.
- Monitor Apps in Default — use PPAC Inventory, Usage, Monitor, and Actions to identify apps, flows, and agents in the default environment with high usage, broad sharing, missing ownership, or elevated risk. Promote production-grade assets to dedicated governed environments. Use the CoE Starter Kit or custom monitoring only for documented gaps not yet covered by PPAC.
- Welcome Messages — if using Managed Environments, enable a Maker welcome message in the default environment to educate makers on using proper environments.

Validation Signals

- No business-critical or regulated workload remains in the default environment without a documented migration or exception plan.
- Default environment assets with broad sharing or high usage are reviewed regularly.
- Makers can clearly identify where to build official solutions.
- Default environment data policy is more restrictive than production workload environments.

Common Risks

- The default environment can become an unmanaged production platform if high-usage assets are not discovered and promoted.
- Broad maker access makes ownership, support, and connector governance harder.
- Restrictive controls without maker guidance can frustrate adoption and increase shadow IT behavior.
- Custom monitoring should not replace PPAC unless a documented PPAC capability gap exists.

Recipe 4: Implement Managed Environments for Scale

Scenario: *"We want to manage many environments consistently with minimal overhead and get insights into usage."*

Enable Managed Environments via the Power Platform Admin Center to unlock governance features designed for enterprise scale. Licensing and entitlement requirements depend on current Microsoft licensing terms, tenant configuration, and the capabilities used; validate licensing before enabling Managed Environments broadly.

Quick Reference

- Use Managed Environments for production, regulated, or broadly adopted workloads that need consistent governance settings.
- Use environment groups and rules to apply governance settings across related environments.
- Use environment routing to move maker-created work away from the default environment.
- Use sharing limits, solution checker enforcement, maker welcome content, and usage insights as standard controls.
- Validate licensing impact before broad rollout.

Key Managed Environment Features

Feature	Benefit
Weekly Digest & Usage Insights	Automatic email summary of top apps, makers, and new resources — spot adoption trends and issues early
Limit Sharing	Cap the number of users an app can be shared with without admin approval
Solution Checker Enforcement	Auto-run quality and performance analysis on solutions before import
DLP at Scale	Simplified DLP policy application across many environments simultaneously
Environment Routing & Groups	Logically group environments by department/region; auto-route user-created apps

Group managed environments logically by department or region to apply governance settings in bulk. Use Default environment routing to automatically redirect user-created apps from the default environment into more governed environments.

Validation Signals

- Production and regulated environments are evaluated for Managed Environment enablement.
- Environment groups are aligned to governance intent such as business unit, region, lifecycle, or sensitivity.
- Rules are reviewed before rollout because centrally enforced settings can affect local environment admins.

- Makers receive clear guidance through welcome messages or onboarding content.

Common Risks

- Enabling controls without validating licensing can create unexpected entitlement or cost issues.
- Environment group rules that are too broad can disrupt workloads with different risk profiles.
- Usage insights without ownership and remediation workflows may not reduce risk.
- Routing makers without onboarding can cause confusion about where official solutions should be built.

Recipe 5: Require Security and Compliance

Scenario: *"We must enforce strong security (MFA, role separation) for those who build or administer Power Platform solutions."*

Use Microsoft Entra ID controls and built-in Power Platform roles to enforce identity and access management best practices.

Quick Reference

- Use Microsoft Entra ID for identity, Conditional Access, MFA, privileged role assignment, and guest governance.
- Apply least privilege for tenant admins, environment admins, makers, and users.
- Separate administrative duties for sensitive workloads and production environments.
- Enable audit logging for Power Platform and Dataverse where compliance or investigation requirements apply.
- Integrate high-risk or regulated telemetry with Microsoft Sentinel or another SIEM when required.

Conditional Access & MFA

- Require Multi-Factor Authentication (MFA) for all users with elevated roles (Power Platform Admin, Environment Admins) and all makers.
- Use Conditional Access policies to restrict Power Platform access from non-compliant devices for admins.

Administrative Roles

- Assign the specific Power Platform Admin roles in Entra ID (e.g., "Power Platform Admin", "Dynamics 365 Admin") rather than Global Admin, following the principle of least privilege.
- Segregation of Duties — for solutions integrating with sensitive systems, require separate accounts or approval mechanisms for critical operations.
- Use Power Automate Approvals or custom approval flows to implement human checkpoints in critical business processes.

Auditing & Logging

- Enable Dataverse Audit Logging to track field-level changes in managed environments.
- Ensure Office 365 Audit Logs capture Power Apps and Power Automate activities.
- Feed logs into a SIEM (e.g., Microsoft Sentinel) for threat monitoring and compliance reporting.

Validation Signals

- Privileged admin roles are assigned to named groups or controlled accounts, not broadly to individuals without review.
- MFA and Conditional Access policies apply to admins and makers according to risk profile.
- Production environments have documented admin access review cadence.
- Audit logs are retained and reviewed according to compliance requirements.

Common Risks

- Excessive admin privileges increase blast radius during mistakes or compromised accounts.
- Weak maker identity controls can allow risky access from unmanaged devices or locations.
- Audit logs without review, retention, or escalation processes provide limited security value.
- Guest access and external sharing can expose data if Microsoft Entra, SharePoint, and Power Platform controls are not aligned.

Recipe 6: Monitor Usage, Compliance, and Performance

Scenario: *"We need to continuously monitor the Power Platform for operational issues, license overuse, or potential misuse."*

Set up proactive monitoring of your Power Platform environments to detect issues before they impact users or compliance.

Quick Reference

- Use PPAC Inventory, Usage, Monitor, Actions, and analytics as the default monitoring experience.
- Track adoption, active assets, connector usage, failures, capacity, license pressure, and policy violations.
- Use Azure Monitor, Application Insights, Log Analytics, or Microsoft Sentinel for critical workloads that need deeper telemetry.
- Define operational thresholds and owners for remediation actions.
- Use CoE Starter Kit or custom dashboards only for documented gaps not covered by PPAC.

Platform Analytics

- Use built-in Power Platform Analytics dashboards (Apps, Flows, Dataverse) in the Admin Center for adoption metrics, storage consumption, and connector usage.

- Use PPAC Inventory, Usage, Monitor, and Actions as the default monitoring experience for inventory, adoption, operational health, licensing attention, and governance insights. Use the CoE Starter Kit or custom dashboards only when a required scenario is not yet available in PPAC, and document the functional gap, owner, support model, and retirement criteria.

Telemetry to Azure

- Enable log streaming to Azure Monitor (Application Insights or Log Analytics) for critical apps and flows.
- In Managed Environments, toggle on "Export to Azure Application Insights" for detailed runtime logs and performance metrics.
- Create custom alerts (e.g., alert when a flow fails N times per hour, or when app response time exceeds a threshold).

License and Capacity Oversight

- Periodically review license assignments and API call consumption per user/flow via the Admin Center's tenant-wide analytics.
- Optimize or scale up plans for flows or users that frequently hit API limits.

Compliance Audits

- Schedule regular audits of environment settings using PPAC, Power Platform admin APIs, PowerShell, CLI, or governed automation. Use CoE Kit compliance components only for scenarios not yet covered natively by PPAC, and document the functional gap, owner, support model, and retirement criteria.
- Document and remediate any configuration drift promptly.

Validation Signals

- Admins can identify high-usage, failing, ownerless, or broadly shared assets from PPAC or approved monitoring workflows.
- Critical apps, flows, and agents have monitoring owners, thresholds, and escalation paths.
- Capacity, license usage, and policy violations are reviewed on a defined cadence.
- Configuration drift is documented, assigned, and remediated.

Common Risks

- Monitoring without ownership becomes passive reporting and does not reduce operational risk.
- Relying only on custom reports can create stale or incomplete visibility if PPAC remains the source of truth.
- Missing thresholds can delay remediation until users experience failures.
- License and capacity issues can become budget or availability problems if reviewed too late.

Recipe 7: Enable ALM and Change Control

Scenario: "We want to ensure all changes go through proper testing and approvals before affecting production users."

Implement Application Lifecycle Management (ALM) practices and guardrails to bring discipline and traceability to every change that reaches production.

Quick Reference

- Build in development environments and promote to test and production through managed solutions.
- Use Power Platform Pipelines, Azure DevOps, or GitHub Actions where deployment automation and approval gates are required.
- Use stage gates for solution checker results, owner approval, security review, and production readiness.
- Take backups or export solutions before major production changes.
- Track version history and source artifacts for critical solutions.

ALM Practices Summary

ALM Practice	Tool / Mechanism	Purpose
Pipeline Deployment	Power Platform Pipelines or Azure DevOps / GitHub Actions	Automated, governed solution promotion Dev → Test → Prod
Change Tickets & Approvals	ServiceNow / work items + stage gate approvals	Formal approval before production deployment
Managed Solutions in Prod	Managed Solution import only	Prevent direct edits in production; enable clean rollback
Backup Before Changes	Power Platform Backup & solution export	Restore point for every major update
Version Control	Git repository via PAC CLI (canvas app source, flow definitions)	Track every change with incremental version numbers

Adopting these ALM practices ensures that every production deployment is traceable, reversible, and approved — protecting end users from untested changes while preserving maker agility in development environments.

Validation Signals

- Production changes are deployed through approved pipelines or documented release processes.
- Production environments use managed solutions rather than unmanaged edits.
- Every production release has approver, version, release notes, backup/rollback plan, and validation result.
- Solution checker or equivalent quality gates are reviewed before production import.

Common Risks

- Direct production edits make changes hard to trace, test, approve, or roll back.

- Skipping solution checker or security review can move performance, reliability, or compliance issues into production.
- Missing rollback plans can increase outage duration during failed deployments.
- Manual deployment without versioning makes audit and incident investigation harder.

Recipe 8: Govern Environment Creation and Lifecycle

Scenario: *"We need to control who can create environments and ensure every environment has a clear purpose, owner, lifecycle, region, and retirement path."*

Govern environment creation through the Power Platform Admin Center to reduce sprawl, protect capacity, and ensure that each environment exists for a documented business or delivery purpose. Treat environment creation as a managed lifecycle process, not an ad hoc maker activity.

Quick Reference

- Use PPAC tenant settings to control who can create production, sandbox, trial, and developer environments.
- Require a request and approval process for production and sandbox environments, including business purpose, owner, region, data sensitivity, expected users, and lifecycle stage.
- Use security groups to restrict environment access and maker permissions for non-default environments.
- Apply naming standards that include business unit or function, workload, region, and lifecycle stage.
- Use Managed Environments for governed workloads and use environment groups to apply rules consistently across related environments.
- Use environment routing to direct makers to governed personal developer environments instead of the default environment.
- Review inactive, unused, duplicate, or ownerless environments periodically and retire, archive, or consolidate them when appropriate.

Validation Signals

- Every non-default environment has a named business owner, technical owner, purpose, lifecycle state, region, and security group.
- Production and sandbox environments are created only through an approved request path.
- Developer and sandbox environments are separated from production workloads and governed with appropriate data policies.
- Managed Environments and environment groups are used for workloads that require consistent governance settings at scale.
- Environment group rules are reviewed before publishing because local environment admins cannot override centrally enforced rules.
- Unused environments are reviewed on a recurring schedule and have documented retention, deletion, or consolidation decisions.

Common Risks

- Environment sprawl increases cost, capacity pressure, operational noise, and security exposure.
- Poor naming and missing ownership make automation, reporting, lifecycle review, and incident response harder.
- Uncontrolled trial or sandbox environments can become informal production environments without backup, support, or compliance review.
- Incorrect region selection can create data residency, latency, or regulatory issues for sensitive workloads.
- If environment groups are not planned carefully, inherited rules can become too broad, too restrictive, or difficult to change after adoption.

Recipe 9: Govern Connectors, Custom Connectors, and HTTP Actions

Scenario: *"We need granular control over which connectors, custom connectors, actions, and HTTP endpoints makers can use across environments."*

Connector governance should start with PPAC data policies and become more restrictive as the workload risk increases. Use classic data policies for broad connector grouping, advanced connector policies where certified connector action-level control is required, and endpoint filtering or exception reviews for HTTP and custom integration scenarios.

Quick Reference

- Use PPAC data policies as the baseline control for connector governance across tenant-wide, environment-specific, and environment group scopes.
- Classify connectors by business trust and data movement risk: Business, Non-Business, or Blocked in classic data policies.
- Use advanced connector policies for stricter allow-list governance and action-level visibility on supported certified connectors.
- Treat custom connectors and HTTP actions as higher-risk integrations that require review of API ownership, authentication, endpoint, data sensitivity, and support model.
- Use connector endpoint filtering where supported to restrict static endpoints for HTTP, SQL Server, Azure Blob Storage, SMTP, browser automation, and UI automation scenarios.
- Define exception handling with business justification, approver, affected environments, expiration date, and recurring review cycle.

Validation Signals

- New connectors are reviewed before being allowed in production or sensitive environments.
- Custom connectors have documented API ownership, authentication method, data classification, and operational support path.
- HTTP actions are blocked or restricted in broad environments and enabled only in approved, purpose-specific environments.
- Advanced connector policies use a default-deny or explicit allow-list approach where granular action control is required.
- Connector exceptions are time-bound, traceable, and reviewed before renewal.

Common Risks

- HTTP and custom connectors can bypass expected governance boundaries if they are broadly enabled without endpoint, authentication, and ownership review.
- New connectors can introduce unreviewed data movement paths if default connector classification is too permissive.
- Overly broad Business connector classification can allow sensitive data to move into services that are not approved for regulated workloads.
- Endpoint filtering may not cover dynamically generated endpoints, so design-time controls should be paired with solution review and monitoring.
- Advanced connector policies do not replace classic data policies for every connector type, so admins must understand which connector types are supported before relying on them as the only control.

Recipe 10: Govern Copilot Studio and AI Agents

Scenario: *"We need to enable Copilot Studio and AI agent innovation while protecting enterprise data, identity, knowledge sources, and publishing channels."*

Govern Copilot Studio agents as Power Platform assets with additional AI-specific controls. Use PPAC data policies, environments, Managed Environments, environment routing, audit logs, and publishing governance to ensure agents are safe to build, test, deploy, and monitor.

Quick Reference

- Use Power Platform environments to separate personal productivity agents, departmental agents, sandbox experiments, and production-grade enterprise agents.
- Use environment routing to provide makers with governed personal developer environments instead of encouraging agent development in the default environment.
- Use PPAC data policies for agents to govern maker and user authentication, knowledge sources, actions, connectors, skills, HTTP requests, triggers, App Insights, and publishing channels.
- Require production agents to document business owner, technical owner, purpose, intended audience, data sources, authentication model, publishing channels, support path, and monitoring plan.
- Apply stricter review for agents that use public websites, external systems, custom connectors, HTTP requests, autonomous actions, or broad publishing channels.
- Use Microsoft Purview audit logs and Microsoft Sentinel integration where compliance, security operations, or investigation requirements apply.
- Use maker welcome messages and security warnings to reinforce privacy, compliance, and responsible AI expectations before agents are published.

Validation Signals

- Every production agent has a named business owner, technical owner, approved environment, intended audience, and support model.
- Agents use only approved knowledge sources, connectors, actions, HTTP endpoints, and publishing channels for their environment risk tier.
- Publishing to broad, external, or high-impact channels requires approval and documented business justification.

- Agent maker activity, policy violations, publishing events, and runtime issues are visible through PPAC, audit logs, or security monitoring integrations.
- Sensitive SharePoint-based knowledge sources are reviewed with information protection and access controls before being connected to agents.

Common Risks

- Agents can expose sensitive or overshared content if knowledge sources inherit broad permissions or are connected without review.
- Broad publishing without approval can create compliance, reputational, or operational exposure.
- Autonomous actions, HTTP requests, and custom connectors can increase risk if authentication, endpoint scope, and business ownership are unclear.
- Agents built in permissive sandbox environments may fail or behave differently when moved to governed production environments.
- Lack of ownership makes incident response, content updates, and retirement decisions difficult.

Recipe 11: Manage Inventory, Ownership, and Criticality

Scenario: *"We need a reliable tenant-wide view of Power Platform assets so we can identify ownership gaps, prioritize risk, and ensure business continuity."*

Use Power Platform Admin Center Inventory as the primary tenant-wide view of agents, apps, flows, environments, and environment groups. Inventory governance turns raw platform visibility into actionable controls for ownership, supportability, criticality, compliance, and lifecycle management.

Quick Reference

- Use PPAC Inventory as the authoritative starting point to discover agents, apps, flows, environments, and environment groups across the tenant.
- Filter and sort inventory by owner, environment, region, resource type, connector usage, creation date, update date, and resource count to prioritize governance reviews.
- Identify orphaned or at-risk assets owned by departed users, inactive accounts, or single individuals supporting business-critical processes.
- Assign both a business owner and a technical owner for every production-grade app, flow, agent, and environment.
- Classify assets by criticality tier, such as Personal Productivity, Departmental, Business-Critical, or Regulated.
- Use PPAC Actions, admin APIs, PowerShell, CLI, or governed automation to support ownership transfer, remediation, reporting, and recurring review workflows.
- Run periodic recertification to confirm owner, purpose, audience, data sensitivity, connectors, environment, support path, and retirement status.

Criticality Tiers

Tier	Typical Use	Governance Expectation
Personal Productivity	Individual productivity or experimentation	Default environment guardrails, limited connectors, low support expectation
Departmental	Team or department process support	Named owners, dedicated environment when appropriate, periodic review
Business-Critical	Operationally important process used by many users	Business and technical owners, ALM, monitoring, backup/restore plan, support model
Regulated	Sensitive, compliance-bound, or externally exposed workload	Security review, stricter data policies, audit logging, access review, exception control

Validation Signals

- Tenant admins can locate any app, flow, agent, environment, or environment group through PPAC Inventory.
- Production-grade assets have both business and technical owners, and ownership is not tied to a single individual account.
- Assets owned by departed users, disabled accounts, or inactive makers are identified and reassigned before they become operational risks.
- Criticality tier, environment, connectors, data sensitivity, and support path are reviewed on a defined cadence.
- High-usage or broadly shared assets in the default environment are reviewed for promotion to governed environments.

Common Risks

- Orphaned apps, flows, and agents can fail silently or become impossible to maintain after the original owner leaves.
- Lack of criticality classification makes it difficult to prioritize monitoring, support, licensing, and remediation effort.
- Broadly shared assets without a business owner can become shadow production systems outside normal support and compliance processes.
- Inventory without an action workflow becomes passive reporting rather than governance.
- Overreliance on exports or custom reports can create stale governance data if PPAC Inventory is not treated as the primary source of truth.

Recipe 12: Govern Licensing, Capacity, and Cost

Scenario: "We need to control Power Platform licensing, capacity consumption, premium connector usage, and cost exposure as adoption scales."

Treat licensing and capacity as governance signals, not only billing concerns. Use PPAC and Microsoft 365 billing processes to monitor storage, capacity add-ons, premium connector usage, API limits, pay-as-you-go consumption, and license assignment patterns before they create budget surprises or operational constraints.

Quick Reference

- Use PPAC and tenant-wide analytics to review license assignments, premium connector usage, API consumption, storage capacity, and environment-level capacity pressure.
- Monitor Dataverse database, file, and log capacity separately and define thresholds for investigation, cleanup, add-on purchase, or environment consolidation.
- Review premium connector usage regularly because premium connectors, custom connectors, Dataverse, HTTP with Microsoft Entra authentication, unattended automation, and advanced automation scenarios can change the licensing model.
- Use capacity add-ons only when the business case, environment, owner, allocation, and expected consumption are documented.
- Govern pay-as-you-go scenarios with approval, budget owner, cost center, usage thresholds, and monthly review.
- Create a license request process that captures workload type, users, connectors, environment, criticality, expected volume, and whether the scenario needs user-based, app/process-based, or capacity-based licensing.
- Use chargeback or showback reports for high-consumption business units so platform cost is visible and tied to business value.

Cost Governance Decision Points

Decision Area	Review Question	Governance Action
Premium connectors	Does the solution require premium or custom connectors?	Validate license impact before production approval.
Dataverse capacity	Is database, file, or log growth approaching threshold?	Clean up, archive, consolidate, or request capacity add-ons.
API and flow limits	Are flows repeatedly hitting action or request limits?	Optimize design or move to the appropriate automation license.
Pay-as-you-go	Is consumption variable or hard to forecast?	Use approval, budget threshold, and monthly review.

Validation Signals

- Admins can explain which apps, flows, agents, environments, and business units drive premium license and capacity consumption.
- Dataverse database, file, and log capacity are reviewed on a defined cadence with documented thresholds and remediation actions.
- Premium connector usage is reviewed before production deployment and periodically after go-live.

- Pay-as-you-go environments have a budget owner, cost center, threshold, and review cadence.
- License requests are connected to workload criticality, expected users, connector requirements, and support model.

Common Risks

- A solution that starts with standard connectors can become a premium-licensed workload after one connector or Dataverse dependency is added.
- Storage growth in files, logs, or audit data can create capacity pressure even when database usage appears controlled.
- Unmonitored pay-as-you-go usage can create unpredictable costs if budgets and thresholds are not defined.
- License assignment without workload ownership can hide underused licenses and make cost optimization difficult.
- Over-optimizing for cost can create fragile designs if makers avoid appropriate premium capabilities for business-critical workloads.

Recipe 13: Strengthen Tenant and Advanced Data Protection Controls

Scenario: *"We need stronger tenant-level and advanced data protection controls for regulated, sensitive, or cross-tenant Power Platform workloads."*

Use advanced protection controls only where business, compliance, or risk requirements justify the additional governance overhead. These controls are not baseline requirements for every workload; they are targeted safeguards for regulated environments, sensitive data, cross-tenant integrations, and scenarios requiring tighter control over Microsoft support access or encryption key ownership.

Quick Reference

- Use Power Platform tenant isolation to restrict cross-tenant inbound and outbound connector-based access where data exfiltration risk or regulatory requirements justify it.
- Maintain explicit allow lists for approved partner, supplier, subsidiary, or multi-tenant scenarios; avoid broad wildcard exceptions unless risk-approved.
- Review guest and B2B collaboration separately from tenant isolation because Power Platform tenant isolation does not replace Microsoft Entra guest access governance.
- Use cross-tenant connection reports to discover existing or attempted cross-tenant connections before enforcing restrictions or tightening allow lists.
- Use customer-managed keys for Dataverse environments that require customer-controlled encryption key lifecycle, including rotation, swap, revocation, and strict separation of duties.
- Use Customer Lockbox for sensitive environments where Microsoft access to customer data must be reviewed, approved, rejected, and audited by administrators.
- Pair advanced controls with clear ownership, documented operating procedures, incident response paths, and periodic review; avoid enabling advanced controls without support readiness.

Advanced Protection Decision Points

Control	Use When	Operational Requirement
Tenant isolation	Cross-tenant connector access must be restricted or explicitly approved.	Maintain allow lists, review connection reports, and validate partner scenarios.
Guest/B2B governance	External users need access to environments, apps, data, or knowledge sources.	Coordinate with Microsoft Entra guest access, Conditional Access, access reviews, and data policies.
Customer-managed key	Regulated workloads require customer control over Dataverse encryption keys.	Manage Azure Key Vault or Managed HSM, key rotation, revocation, and recovery procedures.
Customer Lockbox	Microsoft support access to customer data must require customer approval.	Define approvers, response SLA, audit review, and support-ticket procedures.

Validation Signals

- Cross-tenant connector access is either blocked by default or explicitly allowed through documented tenant allow lists.
- Cross-tenant connection reports are reviewed before enforcement changes and on a recurring cadence for regulated tenants.
- Guest and B2B scenarios have documented access owners, Conditional Access expectations, access review cadence, and data policy coverage.
- Customer-managed key environments have documented key owner, Power Platform admin owner, rotation process, revocation impact analysis, and recovery plan.
- Customer Lockbox requests have assigned approvers, response expectations, audit review procedures, and escalation paths.

Common Risks

- Tenant isolation can disrupt legitimate partner or multi-tenant integrations if existing cross-tenant connections are not discovered and reviewed first.
- Wildcard allow-list exceptions can weaken the intended protection boundary and should require explicit risk approval.
- Guest access may still expose data if Microsoft Entra access governance, SharePoint permissions, and Power Platform data policies are not aligned.
- Customer-managed key misconfiguration, accidental key revocation, or missing recovery procedures can make protected environments unavailable.
- Customer Lockbox can delay support resolution if approvers, SLAs, and escalation paths are unclear.
- Advanced controls can create false assurance if they are enabled without monitoring, testing, documentation, and operational ownership.

Naming Conventions

Use consistent naming conventions to make governance automation, reporting, ownership reviews, environment routing, and incident response easier. Names should be predictable, short enough to scan, and meaningful without requiring tribal knowledge.

Recommended Patterns

Asset Type	Pattern	Examples
Environment	PP-[BU/Function]-[Workload]-[Region]-[Lifecycle]	PP-FIN-ExpenseMgmt-BR-DEV; PP-HR-Onboarding-BR-TEST; PP-OPS-FieldService-BR-PROD
Data policy	DLP-[Scope]-[Sensitivity]-[Purpose]	DLP-Tenant-Baseline-Standard; DLP-Prod-Restricted-Finance; DLP-Default-LowRisk-Productivity
Security group	SG-PP-[Environment]-[Role]	SG-PP-FIN-ExpenseMgmt-PROD-Admins; SG-PP-HR-Onboarding-DEV-Makers; SG-PP-Default-Makers-Restricted
Solution	[Domain].[Capability].[SolutionType]	Finance.ExpenseApproval.CanvasApp; HR.EmployeeOnboarding.CloudFlows; Operations.IncidentManagement.Dataverse
Pipeline	PIPE-[Workload]-[DEV-TEST-PROD]	PIPE-ExpenseMgmt-DEV-TEST-PROD; PIPE-Onboarding-DEV-UAT-PROD
Agent	AGT-[Domain]-[Purpose]-[Audience]-[Lifecycle]	AGT-HR-Onboarding-Employees-PROD; AGT-IT-Helpdesk-Internal-UAT
Exception record	EXC-[Control]-[Workload]-[ExpirationYYYYMM]	EXC-DLP-ExpenseMgmt-202612; EXC-HTTP-FieldService-202609

Naming Rules

- Use stable business terms rather than temporary project nicknames.
- Keep lifecycle values consistent: DEV, TEST, UAT, PROD, SANDBOX, or ARCHIVE.
- Include region when data residency, latency, or support ownership matters.
- Avoid personal names in asset names; capture ownership in metadata, inventory, or support records instead.
- Use the same workload name across environments, solutions, pipelines, security groups, and agents to simplify reporting and automation.
- Review names during environment creation, solution approval, and production readiness review.

Exception Process

Use exceptions to handle valid business needs that cannot comply with the standard governance baseline. Exceptions must be deliberate, time-bound, risk-reviewed, and traceable. They should never become a permanent workaround for missing governance design, weak ownership, or unclear requirements.

When to Allow an Exception

- A documented business requirement cannot be met by the standard policy, environment, connector, licensing, or security baseline.
- The workload owner accepts the risk and provides a clear business justification.
- The exception has a defined scope, affected environments, affected assets, expiration date, and review owner.
- The platform, security, or compliance team confirms that compensating controls are sufficient for the requested duration.
- There is a plan to remove, reduce, or replace the exception when PPAC capabilities, design changes, or process improvements make it unnecessary.

Required Exception Record

Field	What to Capture
Exception ID	Use the naming pattern EXC-[Control]-[Workload]-[ExpirationYYYYMM].
Control or policy	Identify the affected data policy, connector rule, environment rule, security control, licensing control, or monitoring requirement.
Business justification	Describe why the standard control cannot be followed and what business outcome depends on the exception.
Scope and duration	List affected environments, apps, flows, agents, connectors, users, start date, expiration date, and review cadence.
Risk and compensating controls	Document data sensitivity, exposure risk, monitoring, access restriction, logging, approval gates, and rollback options.
Owners and approvers	Capture business owner, technical owner, platform owner, security/compliance approver, and renewal approver.

Approval Workflow

1. Requester submits the exception record with business justification, affected assets, proposed duration, and compensating controls.
2. Platform team validates technical feasibility, PPAC alternatives, automation options, and expected operational impact.
3. Security and compliance team reviews data sensitivity, access exposure, logging, monitoring, and regulatory impact.
4. Business owner accepts residual risk and confirms accountability for the exception outcome.
5. Approver grants, rejects, or requests changes. Approved exceptions are logged, monitored, and scheduled for review before expiration.
6. At expiration, the exception is either removed, renewed with updated justification, or converted into a standard governed pattern.

Validation Signals

- Every exception has an ID, owner, approver, affected control, affected assets, expiration date, and review cadence.
- No exception remains active after expiration without formal renewal.
- Exceptions are reviewed alongside inventory, monitoring, data policy, and production readiness reviews.
- Repeated exceptions trigger a review of the standard governance baseline or solution design.
- Exception records are searchable and tied to named assets, environments, connectors, agents, or workloads.

Common Risks

- Open-ended exceptions become permanent governance bypasses.
- Exceptions without asset scope are difficult to monitor, renew, or remove safely.
- Business approval without technical and security review can hide operational or compliance risk.
- Too many repeated exceptions indicate that the baseline policy, environment strategy, or maker enablement model may need redesign.
- Lack of review cadence can leave risky connectors, broad publishing, cross-tenant access, or premium cost exposure active longer than intended.

Governance Validation Checklist

Use this checklist during governance reviews, production readiness assessments, periodic recertification, and platform health checks. Treat unchecked items as remediation actions, risk acceptances, or documented exceptions.

Platform Governance

- PPAC is the primary source for governance, inventory, monitoring, security, and administrative actions.
- CoE Starter Kit or custom solutions are used only for documented PPAC capability gaps.
- Platform, environment, maker, business owner, and security/compliance responsibilities are documented.
- Maker onboarding explains environments, data policies, naming standards, ALM, support paths, and exception rules.

Environments and Lifecycle

- Environment creation is controlled through PPAC tenant settings and an approved request process.
- Every non-default environment has purpose, business owner, technical owner, lifecycle state, region, and security group.
- Production, sandbox, developer, UAT, and default environments have clearly separated purposes.
- Managed Environments, environment groups, rules, and environment routing are used where governance at scale is required.
- Unused, duplicate, ownerless, or inactive environments are reviewed and retired, archived, or consolidated.

Data Policies and Connector Governance

- Data policies classify connectors as Business, Non-Business, or Blocked based on trust and data movement risk.
- New connectors have a conservative default classification and are reviewed before sensitive or production use.
- Custom connectors, HTTP actions, and advanced connector policies are reviewed for authentication, endpoint, ownership, and data sensitivity.
- Connector exceptions are time-bound, traceable, approved, and reviewed before renewal.
- Policy impact is reviewed before changes because existing apps and flows may be affected at design time or runtime.

Default Environment

- The default environment is treated as personal productivity only, not production hosting.
- Default environment data policies are restrictive enough to prevent risky connector combinations.
- High-usage, broadly shared, ownerless, or risky assets in default are reviewed through PPAC Inventory, Usage, Monitor, and Actions.
- Production-grade assets in default have a migration, retirement, or exception plan.

Security, Compliance, and Monitoring

- Microsoft Entra ID, MFA, Conditional Access, least privilege, and role separation are applied according to workload risk.
- Production admin access is reviewed on a defined cadence.
- Power Platform and Dataverse audit logs are enabled and retained where compliance or investigation requirements apply.
- Critical apps, flows, and agents have monitoring owners, thresholds, alerts, and escalation paths.
- Configuration drift, capacity pressure, license usage, and policy violations are reviewed and remediated regularly.

ALM and Production Readiness

- Production changes are deployed through managed solutions and approved release processes.
- Pipelines or documented deployment workflows include stage gates for testing, owner approval, security review, and solution quality.
- Every production release has version, approver, release notes, validation result, and rollback or restore plan.
- Critical solutions have source artifacts, backup/restore expectations, and support ownership documented.

AI Agents and Knowledge Sources

- Production agents have business owner, technical owner, intended audience, approved environment, support model, and monitoring plan.
- Agent knowledge sources, connectors, actions, HTTP endpoints, triggers, and publishing channels are approved for the environment risk tier.
- Sensitive SharePoint or enterprise knowledge sources are reviewed for access scope, oversharing risk, and information protection.
- Broad, external, or high-impact agent publishing requires documented approval.

Inventory, Ownership, Licensing, and Cost

- PPAC Inventory is used to discover agents, apps, flows, environments, and environment groups across the tenant.
- Production-grade assets have business and technical owners and are not dependent on a single individual account.
- Criticality tier, support model, connectors, data sensitivity, and retirement status are reviewed on a defined cadence.
- Dataverse database, file, and log capacity have thresholds, owners, and remediation actions.
- Premium connector usage, pay-as-you-go usage, capacity add-ons, and license requests are tied to workload ownership and business value.

Tenant Protection, Naming, and Exceptions

- Tenant isolation, guest/B2B governance, customer-managed keys, and Customer Lockbox are used only when risk, compliance, or business requirements justify the operational overhead.
- Cross-tenant allow lists, guest access reviews, key management procedures, and Lockbox approvers are documented where applicable.
- Naming conventions are applied consistently across environments, data policies, security groups, solutions, pipelines, agents, and exceptions.
- Exceptions have ID, business justification, owner, approver, affected assets, compensating controls, expiration date, and review cadence.
- Repeated exceptions trigger a review of the governance baseline or solution design.

Closing Principles

By following these governance recipes, you can confidently scale Power Platform solutions while minimizing risk and maintaining control. Adjust each recipe to fit your organization's specific compliance requirements and culture.

Remember: good governance is a balance — protect and control the platform without stifling the innovation and agility that Power Platform offers to business users.